

Mata Kuliah DevSecOps

PANDUAN PRAKTIKUM

Threat Modeling dengan OWASP
Threat Dragon

Pertemuan 2 | Shift-Left Security dalam SDLC

April Rustianto, S.Komp., M.T., CCIE



SEKOLAH TINGGI TEKNOLOGI
TERPADU NURUL FIKRI



Tujuan Praktikum

- Membuat Data Flow Diagram (DFD) untuk sistem aplikasi web
- Mengidentifikasi ancaman keamanan menggunakan metode STRIDE
- Merancang mitigasi untuk setiap ancaman yang ditemukan
- Menulis security requirements berbasis OWASP ASVS
- Mendokumentasikan hasil threat modeling dalam laporan terstruktur



Durasi: 60 menit



Kelompok: 3-4 orang



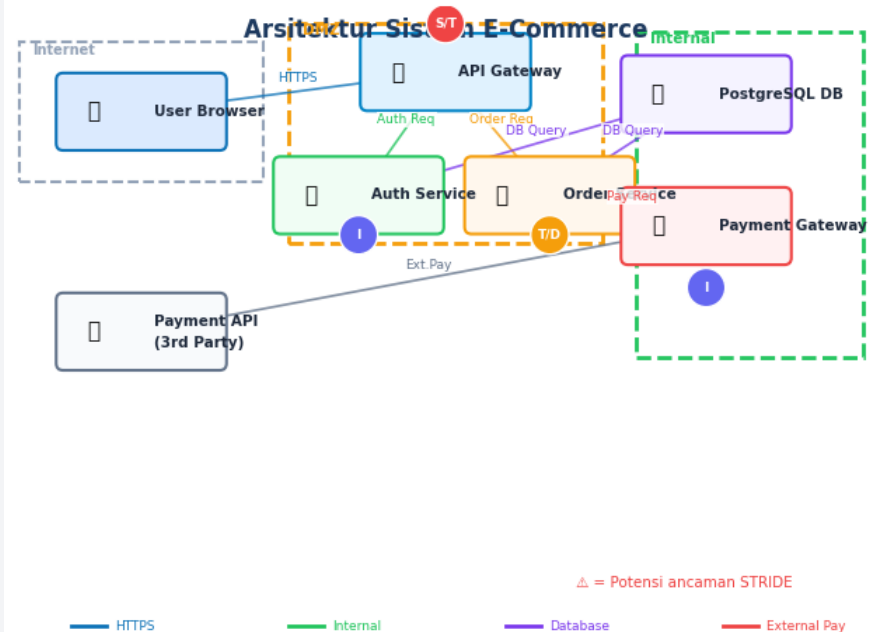
Output: 3 dokumen

Skenario Sistem yang Akan Dianalisis

Aplikasi Pemesanan Online (E-Commerce)

- 🌐 Frontend (React/Vue.js) — antarmuka pengguna web & mobile
 - 🛡️ Auth Service — autentikasi dan otorisasi pengguna
 - 📦 Order Service — pemrosesan dan manajemen pesanan
 - 💳 Payment Gateway — integrasi pembayaran pihak ketiga
 - 🗄️ Database (PostgreSQL) — data pengguna & transaksi
-
- Trust Boundary: Internet ↔ DMZ ↔ Internal Network
 - Semua komunikasi antar layanan melalui API Gateway

Arsitektur Sistem





Langkah-Langkah Praktikum

Langkah 1: Setup OWASP Threat Dragon

 **Durasi: 10 menit**

- 1. Buka browser → akses <https://www.threatdragon.com>
- 2. Klik "Login with GitHub" atau pilih "Use Offline Mode"
- 3. Klik "New Threat Model" untuk membuat model baru
- 4. Isi metadata: Title, Reviewer, Owner, Description
- 5. Pilih diagram type: Data Flow Diagram (DFD)
-  Cek: Dapat membuat project dan DFD kosong
-  Alternatif: Threat Dragon Desktop (offline)

Tool Setup



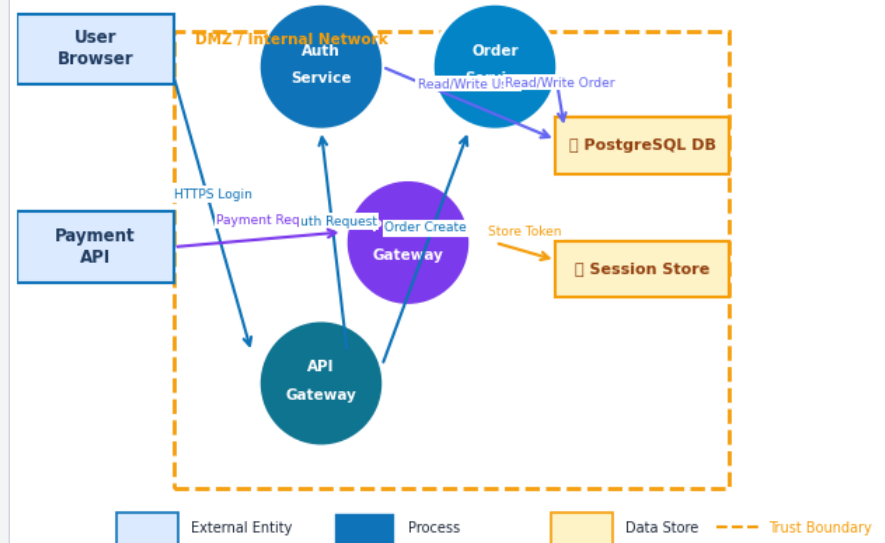
Langkah 2: Membuat Data Flow Diagram (DFD)

 **Durasi: 20 menit**

- 1. Tambahkan External Entity: User Browser, Payment API
- 2. Tambahkan Process: Auth Service, Order Service, Payment GW
- 3. Tambahkan Data Store: PostgreSQL DB (beri nama label)
- 4. Hubungkan komponen dengan aliran data (arrows) berlabel
- 5. Gambar Trust Boundary (kotak putus-putus) antar zona
-  Minimum: 6 komponen, 8 aliran, 2 trust boundary
-  Tips: Label aliran data, contoh: "Login Request [HTTPS]"

DFD Elements

Contoh Data Flow Diagram (DFD)



Langkah 3: Identifikasi Ancaman STRIDE

 **Durasi: 15 menit**

- 1. Klik setiap komponen/aliran di DFD Threat Dragon
- 2. Klik "Add Threat" → isi form di panel kanan
- 3. Pilih kategori STRIDE yang sesuai:
 - S — Spoofing: penyamaran identitas pengguna
 - T — Tampering: modifikasi data transaksi
 - R — Repudiation: penyangkalan transaksi
 - I — Info Disclosure: kebocoran data payment
 - D — Denial of Service: serangan DDoS di checkout
 - E — Elevation of Privilege: akses admin tanpa auth
-  Minimum: 8 ancaman berbeda di seluruh DFD

STRIDE

Kategori STRIDE

Panduan Identifikasi Ancaman		
EAT	Nama Ancaman	Contoh pada Sistem E-Commerce
	Spoofing ☐ Komponen yang membutuhkan autentikasi	JWT tanpa validasi, Auth Service tanpa MFA
	Tampering ☐ Aliran data yang dapat dimodifikasi	Payload Order tanpa signature, Data DB tanpa integrity check
	Repudiation ☐ Aksi yang tidak dapat dilacak	Transaksi tanpa audit log, Delete tanpa record
	Info Disclosure ☐ Data sensitif yang berpotensi bocor	API response dengan data kartu kredit, Error message verbose
	Denial of Service ☐ Endpoint yang dapat dibanjiri request	Login endpoint tanpa rate limiting, Payment GW tanpa circuit breaker
	Elevation of Privilege ☐ Fungsi admin yang dapat diakses user biasa	Admin API tanpa role check, JWT algorithm confusion attack

Langkah 4: Merancang Mitigasi

 **Durasi: 10 menit**

- 1. Untuk tiap ancaman, isi field di Threat Dragon:
 - Mitigation: langkah mitigasi teknis yang konkret
 - Status: Open / Mitigated / Not Applicable
 - Priority: High / Medium / Low
- 2. Contoh mitigasi konkret:
 - Spoofing Login → Implementasi MFA (TOTP/SMS OTP)
 - SQL Injection → Gunakan Parameterized Query / ORM
 - MITM Payment → Enforce TLS 1.3 + Certificate Pinning
- ☒ Tiap ancaman harus memiliki minimal 1 mitigasi spesifik

Mitigation

Edit Threat — OWASP Threat Dragon

Threat Name
SQL Injection pada Order Service endpoint /api/orders

STRIDE Category
Tampering ▼

Description
Penyerang dapat memanipulasi query SQL melalui parameter yang tidak di-sanitasi pada endpoint pembuatan order.

Mitigation
Implementasi Prepared Statement / ORM Hibernate.
Validasi input dengan whitelist di layer API Gateway.

Status
Open Mitigated

Priority
N/A High Medium Low

 **Save Threat**

Langkah 5: Menulis Security Requirements



Durasi: 5 menit

- 1. Buat tabel Security Requirements (Word/Google Docs)
- 2. Kolom: ID | Requirement | ASVS Ref | Priority | Status
- 3. Contoh security requirements:
 - SR-01: API endpoint wajib autentikasi JWT [ASVS 2.1.1]
 - SR-02: Password hash bcrypt cost ≥ 12 [ASVS 2.4.1]
 - SR-03: Input validation di semua form field [ASVS 5.1.3]
 - SR-04: Log setiap akses ke data sensitif [ASVS 7.1.1]
 - SR-05: Rate limiting login: max 5 req/menit/IP [ASVS 2.2.1]
-  Minimum: 5 security requirements berbasis ancaman

OWASP ASVS

Tabel Security Requirements

Berdasarkan OWASP Application Security Verification Standard (ASVS)

ID	Security Requirement	ASVS Ref	Priority	Status
SR-01	Semua API endpoint wajib menggunakan autentikasi JWT Bearer token yang valid	ASVS 2.1.1	High	Open
SR-02	Password harus di-hash dengan bcrypt (cost factor ≥ 12)	ASVS 2.4.1	High	Mitigated
SR-03	Semua input form harus divalidasi sisi server dengan whitelist karakter yang diizinkan	ASVS 5.1.3	High	Open
SR-04	Setiap akses ke data pembayaran harus dicatat dalam audit log dengan timestamp	ASVS 7.1.1	Medium	Open
SR-05	Rate limiting login endpoint: maksimal 5 request per menit per IP	ASVS 2.2.1	Medium	Open

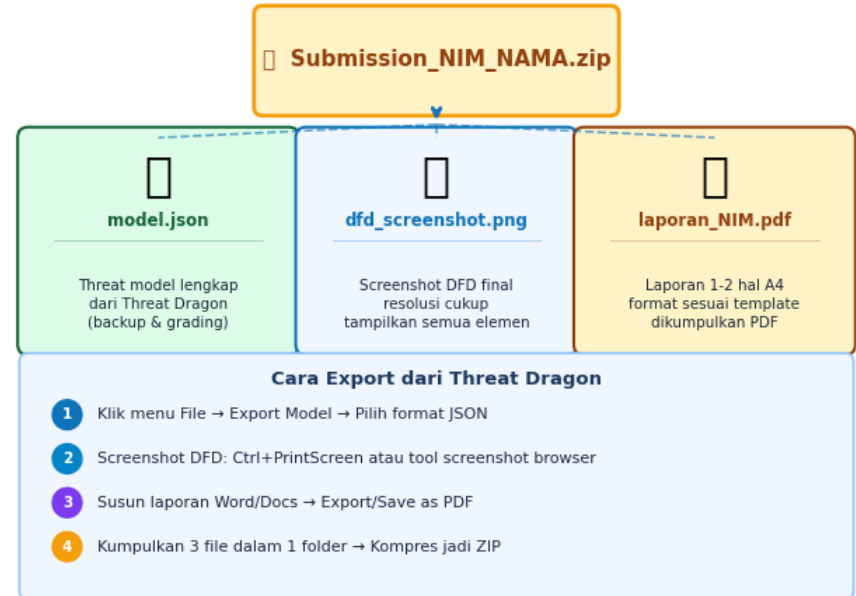
Langkah 6: Export dan Menyusun Laporan

 **Durasi: 5 menit**

- 1. Export dari OWASP Threat Dragon:
 - File → Export → JSON (simpan model lengkap)
 - Screenshot DFD final dalam format PNG/JPG
- 2. Susun Laporan Praktikum (1-2 halaman A4):
 - Header: Nama, NIM, Kelompok, Tanggal Praktikum
 - Deskripsi Sistem + Screenshot DFD
 - Tabel Ancaman STRIDE (minimal 8 baris)
 - Tabel Mitigasi per ancaman
 - Tabel Security Requirements (minimal 5 baris)
 - Refleksi: apa yang dipelajari (3-5 kalimat)
-  **Submit: File JSON + Screenshot DFD + PDF Laporan**

Documentation

Struktur Deliverable Praktikum



Rubrik Penilaian Praktikum

Komponen	Bobot	Kriteria Penilaian
Data Flow Diagram	25%	Min 6 komponen, 8 aliran data berlabel, 2 trust boundary jelas
Identifikasi STRIDE	30%	Min 8 ancaman, kategori STRIDE tepat, deskripsi konkret
Mitigasi	20%	Tiap ancaman ter-mitigasi, solusi teknis spesifik dan realistis
Security Requirements	20%	Min 5 SR terstruktur, referensi ASVS, format lengkap
Laporan & Refleksi	5%	Dokumen lengkap, screenshot DFD ada, refleksi 3-5 kalimat

Format Laporan Praktikum

Template Laporan Individual

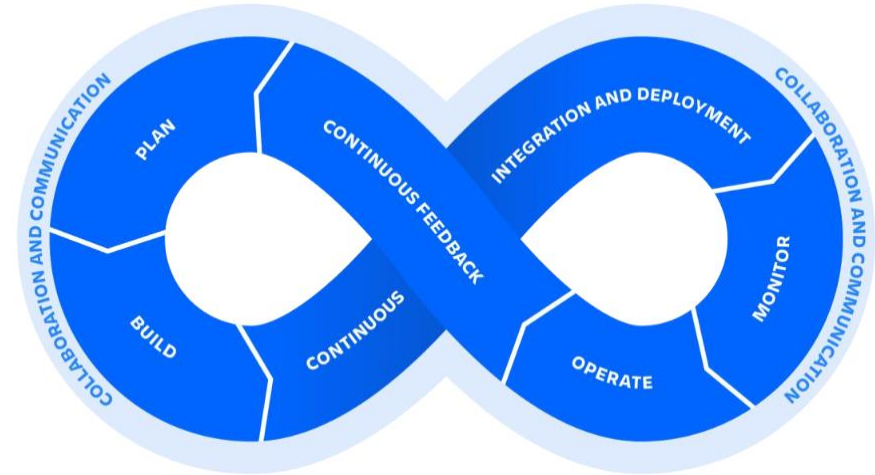
- 1. HEADER: Nama, NIM, Kelas, Kelompok, Tanggal
- 2. SISTEM: Deskripsi singkat sistem (3-5 kalimat)
- 3. DFD: Screenshot Threat Dragon + penjelasan
- 4. ANCAMAN: Tabel STRIDE — minimal 8 baris
 - Kolom: No | Komponen | Kategori | Ancaman | Severity
- 5. MITIGASI: Tabel mitigasi per ancaman
 - Kolom: No | Ancaman | Mitigasi | Status | Priority
- 6. SECURITY REQUIREMENTS — minimal 5 baris
 - Kolom: ID | Requirement | ASVS Ref | Priority | Status
- 7. REFLEKSI: 3-5 kalimat tentang pembelajaran praktikum

Format Submission

Submit sebagai ZIP:

model.json

dfd_screenshot.png



Tips Sukses Praktikum

"Threat modeling yang baik dimulai dari memahami sistem, bukan dari daftar ancaman"

Yang Harus Dilakukan



- Baca skenario sistem sebelum mulai
- Label SEMUA aliran data di DFD
- Tulis mitigasi SPESIFIK per ancaman
- Gunakan referensi OWASP ASVS untuk SR
- Simpan progress berkala (Export JSON)

Yang Harus Dihindari



- DFD tanpa trust boundary
- Mitigasi umum tanpa detail teknis
- Hanya fokus satu kategori STRIDE
- Melupakan Data Store dalam DFD
- Copy-paste tanpa sesuaikan skenario

Penting Diingat



- Threat Dragon simpan dalam JSON
- STRIDE = 6 kategori ancaman
- Tiap komponen DFD bisa berancaman
- Security requirement harus testable
- Cegah masalah sebelum coding dimulai

[illegible]